第五课 TCP/IP

TCP/IP 体系

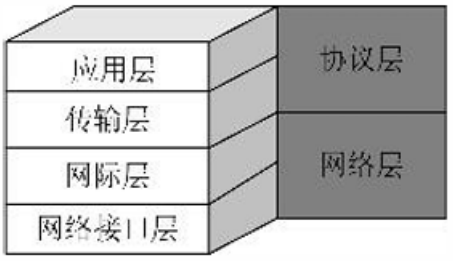
分层特点

应用层 + 传输层 + 网际层 + 网络接口层

与OSI模型七层不同的是：TCP/IP协议 栈更加侧重于互联设备间的**数据传送**，而不是严 格的功能层次的划分

也可分为两层：

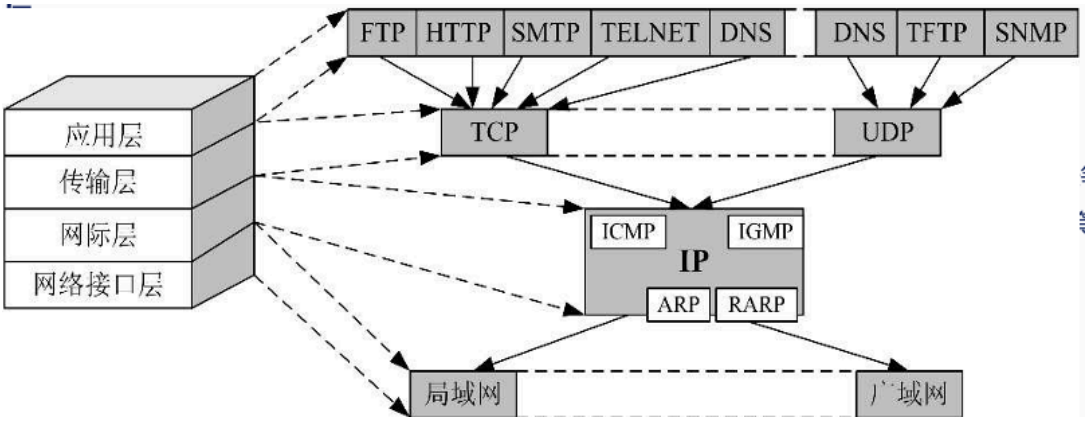
- **协议层**：具体定义了有关网络通信 协议的类型
- **网络层**：具体定义了网络的 类型（如局域网和广域网）和设备之间的路径选 择



1、核心特点

- **相邻层之间通过接口通信：** 每一层只与相邻层交互，上层使用下层提供的服务，下层为上层提供支持。
- **封装与解封装：** 数据向下传递时，每一层都会添加自己的协议头（封装）；向上传递时，每一层会去掉对应的协议头（解封装）。
- **各层独立设计：** 每一层的设计相对独立，只需关注本层功能和与相邻层的接口，使得各层可以独立发展（如链路层更换技术不影响上层）。

2、各层主要功能



- 网络接口层

  主要功能：负责通过网络**发送和接收分组**，与物理网络**硬件**交互，负责帧的封装与解封装、硬件地址（MAC）处理、错误检测与纠正（如CRC）、介质访问控制（如CSMA/CD、CSMA/CA）及链路管理。

  常见协议： 以太网协议 (Ethernet)、无线局域网协议 (WLAN/802.11)、点对点协议 (PPP)

- 网际层

  主要功能： 核心层，负责**数据包**从源主机到目的主机的传输，提供**无连接**的、**不可靠**的传输服务。功能包括IP寻址与路由选择、分片与重组、无连接数据传输、网络层协议的封装与解封装。

  常见协议： IP协议、ARP协议（地址解析）、ICMP协议（错误和控制消息）、IGMP协议（管理IP多播组）

- 传输层

  主要功能： 负责在源主机和目的主机的**应用程序**之间提供端到端的通信服务。功能包括可靠性与不可靠性服务、流量控制（如滑动窗口机制）、拥塞控制、多路复用与分解（通过端口号区分应用）。

  常见协议： TCP（提供**可靠**、**面向连接**的服务）、UDP（提供简单**不可靠**、无连接的服务）。

- 应用层

  主要功能： 最高层，直接面向用户和应用程序，**提供各种网络应用服务**（如网页、邮件、文件传输等），定义应用层协议，提供用户接口并进行数据格式化。

  常见协议： HTTP/HTTPS（网页）、FTP/SFTP（文件传输）、SMTP/POP3/IMAP（电子邮件）、DNS（域名解析）、SSH（安全远程登录）。

连接建立（三次握手）

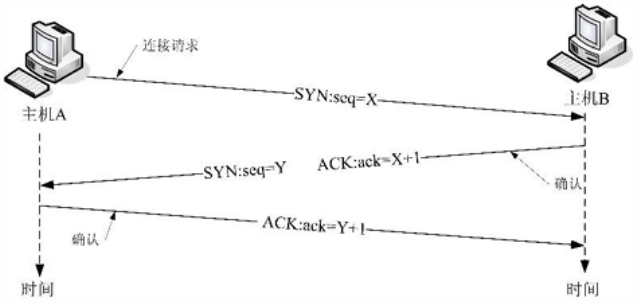


图5-22 TCP连接建立时的三次握手

- 主机A向主机B发送 **SYN** 报文段，告知对方“我的初始化序列号 seq 是 X”，从而实现A到B的序列号同步。
- 如果主机B同意建立连接，会向主机A发送 **SYN、ACK** 报文段。这表示：告知主机B的初始化序列号 seq 是 Y，同时将确认序号 ack 设为 X + 1（表示等待接收第 X + 1 号字节数据流），从而实现B到A的序列号同步。
- 主机A向主机B发送 **ACK** 确认报文段，将确认序号 ack 设为 Y + 1。

针对TCP连接过程的攻击

TCP SYN 泛洪攻击 (SYN Flood Attack)

最常见的一种拒绝服务（DoS）攻击形式

- **原理：** 攻击者利用TCP三次握手的机制，发送大量的SYN连接请求，但由于目的主机接收到的SYN报文段中的IP地址都是**伪造** 的，所以发送出去的SYN+ACK确认报文段全部得不到回复。
- **后果：** 这会导致服务器端产生大量处于**“半开放”**状态的连接，从而**占用大量的系统资源**（如内存、CPU），最终导致服务器**无法处理正常的连接请求**，造成服务中断。
- **防御：** 建议在Windows系统中通过**修改注册表参数**（如启用**SynAttackProtect**，设置TcpMaxHalfOpen等阈值）来**限制半开放连接的数量**，增强防御能力。

重要协议及攻击

DNS安全

1、定义

Domain Name System，域名系统

位于**应用层**，使用 TCP和UDP进行传输（多数情况下使用 UDP以减少开销）

一组协议和服务，它允许用户在查找网络资源时使用层次化的对用户友好的名字取代IP地址，即对主机名（域名）与对应的IP地址之间建立映射关系。

核心功能：将易于记忆的**主机名映射为 IP 地址**

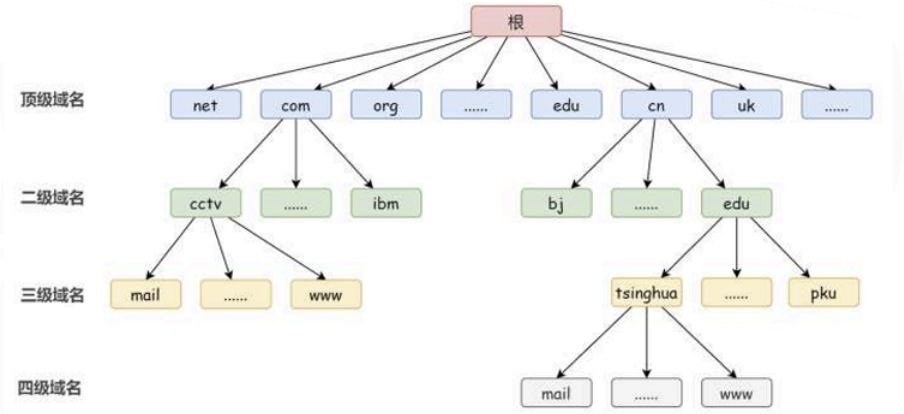
🪄 用户输入 www.sina.com.cn，DNS 服务器会将其解析为对应的 IP 地址（如 202.106.184.200）

2、优点

- 域名相比数字化的 IP 地址更易于记忆
- 即使后端服务器的 IP 地址发生变更，域名通常保持不变，增强了网络的稳定性

3、DNS的组成与架构

- **分布式数据库：** DNS 系统由分布式数据库组成，采用**层次化的域名空间**。
- **树状结构：** DNS 的命名结构类似文件系统，但**解析路径方向相反**（从具体主机到根域，如 sina.com）。它采用树状结构组织域名，顶级域名下可包含多个子域，每个子域下又包含多个主机。



域名层次结构

- **DNS 服务器：** 这是 DNS 系统的核心，负责存储域名和 IP 地址的映射关系，并处理客户端的解析请求。

4、工作特性

- **解析过程：** 这种由 DNS 服务器在其数据库中查找并返回客户端所需 IP 地址的过程，被称为**“主机名称解析”**。其工作流程类似电话簿查询，如果一台服务器无法提供答案，会将请求转发给其他 DNS 服务器（分布式）。
- **传输协议：** DNS 同时使用 **TCP 和 UDP** 进行传输。为了减少开销，在绝大多数情况下，DNS 使用 **UDP** 协议进行通信；TCP 端口（TCP 53）则主要用于 DNS 区域数据的复制。

5、针对性攻击

- **缓存中毒**

  缓存：DNS为了提高查询效率，采用了缓存机制，把用户查询过的最新记录存放在缓存 中，并设置生存周期 TTL

  原理： 攻击者在DNS服务器的缓存中存入大量错误的数据 记录主动供用户查询，由于DNS记录的同步复制，所以在TTL内，缓存中毒的DNS服务器有可能将 错误的记录发送给其他的DNS服务器，导致更多的DNS服务器中毒。。

  后果： 后续用户查询该域名时，会得到错误的 IP 地址，从而被重定向到攻击者控制的恶意网站（如钓鱼网站）。

- **DNS 拒绝服务攻击** （DOS）

  原理:

  - **流量洪水（洪范攻击）：** 攻击者利用海量**查询请求**淹没 DNS 服务器，导致其因过载而无法响应正常请求。
  - **放大攻击 (Amplification Attack)：**查询的响应往往远大于查询请求本身，攻击者将被攻击者主机 IP 作为源地址向大量公共 DNS 发送请求，导致被攻击主机**被大量 DNS 响应包淹没**。
  - **幻影域名攻击 (Phantom Domain Attack)：** 通过发送大量针对不存在的子域或响应极慢的

域名查询，拖垮 DNS 服务器的解析资源。

- **DNS 劫持**

  原理： 攻击者通过采用非法手段获得某一个**域名管理员**的账户和密码，或者**域名管理邮箱**，直接**篡改 DNS 服务器上的记录**，或通过恶意软件修改用户的本地 DNS 设置，将查询重定向到攻击者指定的域名服务器。

  后果： 与缓存中毒类似，它会导致用户访问错误的网站，但这种攻击通常作用于**权威服务器或特定的 DNS 配置**，影响范围可能更广、持续时间更长。

ARP安全

1、定义

Address Resolution Protocol，地址解析协议

将 **IP 地址映射到 MAC 地址** 的网络协议。它主要用于在局域网（如以太网）中，让设备能够根据目标 IP 地址找到对应的物理硬件地址（MAC地址），从而完成**数据帧**的传输。

位于 TCP/IP 参考模型的 **网际层（网络层）与网络接口层（数据链路层）之间**。

2、工作特性

- **缓存查询：** 当设备需要发送数据时，先检查本地的 **ARP 缓存表**（存储了IP-MAC映射）。
- **ARP 请求（广播）：** 若缓存中未找到目标 IP 的 MAC 地址，设备会以“广播”形式发送 ARP 请求（如：“谁是 192.168.1.3，请告诉我你的 MAC 地址？”）。
- **ARP 响应（单播）：** 网段内所有主机都会收到广播，但只有对应的目标主机（192.168.1.3）会通过“单播”消息回应自己的 MAC 地址。
- **学习与更新：** 请求方收到响应后，会将映射关系记录到自己的缓存表中。

3、针对性攻击

ARP欺骗

由于 ARP 协议在设计时过于信任局域网内的信息，导致存在严重的安全漏洞，容易遭受 **ARP 欺骗**：

- **攻击原理：**

  ARP 协议允许设备“主动发送公告”或响应未经请求的报文。攻击者可以伪造虚假的 ARP 响应，报文中的源IP地址和源MAC地址（告知受害者“我是网关，MAC地址是攻击者的MAC”），强行将受害者的 ARP 缓存表修改为错误信息。

- **攻击目的：**
  - **拦截/嗅探信息：** 使受害者的流量流向攻击者（作为“中间人”），从而窃取敏感信息。
  - **中断通信（DoS）：** 扰乱局域网内主机的 ARP 表，导致受害者无法访问网关或互联网，引发网络瘫痪。

- **对交换机的攻击：**

  攻击者通过伪造海量随机的 MAC 地址，快速填满交换机的 **CAM 表（MAC 地址表）**。当 CAM 表溢出后，交换机会失去正常转发能力，被迫以“广播”方式转发流量，从而使攻击者能够嗅探到原本不属于自己的网络流量。

防御措施：

- **静态绑定：** 在计算机上手动通过 arp -s 命令绑定网关 IP 与 MAC 地址（防止被动态更新篡改）。
- **批处理自动执行：** 编写 .bat 脚本开机自动设置静态 ARP 记录。
- **开启安全功能：**
  - 在交换机上启用 **端口安全（Port Security）** 功能（如限制最大 MAC 地址数量、指定允许的 MAC 地址）。
  - 在网络设备上启用 **动态 ARP 检测（DAI）** 等防护功能。
  - 使用支持 ARP 绑定的防火墙或安全软件。

IP

TCP/IP 模型中**网际层（或网络层）**的核心协议。它负责在复杂的网络环境中进行数据报的传输。

1、核心功能

- **IP寻址与路由选择：** 使用 IP 地址标识网络中的设备，并通过路由算法选择最佳路径将数据包传输到目的地。
- **分片与重组：** 当较大的数据报超过物理网络的最大传输单元（MTU）时，IP 协议会将其分割成较小的片段（分片）进行传输，并在接收端主机重新组装。
- **提供无连接与不可靠服务：** 提供“尽力而为”的传输服务，不保证数据包是否能可靠、按序到达，也不防范重复。

2、工作过程

网络层接收上层（如传输层）的数据并封装上 IP 头部形成 IP 数据报；随后根据路由表寻找下一跳，最终送达目标主机进行解封装。

3、针对性攻击

（1）针对头部的安全

头部漏洞指的是协议头部与标准不符的情况， 攻击者通过违反协议规定（例如将某些字段设为 不允许的值），生成**无效头部**，消耗系统资源，可能 导致系统性能下降或资源耗尽，**引发拒绝服务攻击**。

- **碎片攻击**

  原理： 攻击者利用 IP 报文头部中的“**偏移量**”和“**标志位**”字段构造异常分片。例如，故意使分片之

间存在**重叠**，或者设置极大的偏移量，导致接收端在重组报文时超出操作系统 64KB（65536字节）的**缓冲区限制**。

后果： 导致接收端主机**分配内存出错**，引发**操作系统瘫痪**。

- **死亡之ping**

  原理： 攻击者基于碎片攻击，ICMP 报文借 IP 报文传输，攻击者**构造超长**（超过 64KB 限制）的 **ICMP 请求报文** 。

  后果： 早期路由器或主机在读取头部后为其**分配内存缓冲区时会出错**，导致系统崩溃

（2）针对协议的安全

利用协议规范或实现中 的漏洞引发的安全问题，数据包符合规范，但与协议执行过程存在冲突

- **不按序发送数据包**：协议实现有序，双方应按约定顺序收发数据包。否则会致协议执行错误，如 TCP 连接的三次握手，若一方不按序操作导致大量“半开放”连接，都会耗尽对方资源。
- **数据包到达速度异常**：协议执行中各交互环节需在规 定时间内完成。到达太慢或太快都有问题，太慢如共 享资源时一方迟缓致对方久等，太快易引发拒绝服务 攻击，影响对方后续操作。
- **数据包丢失**：数据包丢失原因多样，不同协议处理方 式不同。若要求丢包重传，对缓存区设计要求高，可 能引发缓存区溢出攻击。

（3）针对验证的安全

- **IP欺骗**

  原理：攻击者伪造数据包的源IP地址来误导通信

- **基于ICMP 的IP欺骗**

  IP欺骗常与 ICMP（Internet控制消息协议） 配合进行攻击，

  - **ICMP应答欺骗攻击**：

    攻击者伪造受害者 IP 发送大量 ICMP 请求，迫使受害者响应海量报文，导致拒绝服务（DoS）。

  - **ICMP广播放大攻击**：

    攻击者伪造受害者 IP 向网络发送**广播请求**，网络内所有主机同时回应，产生海量流量**冲击路由器**，导致网络瘫痪。